



MINOR PROJECT REPORT

Analysis of Authentication and Authorization Vulnerabilities in Web Applications

1 INTRODUCTION

In modern web applications, security is a critical requirement due to the handling of sensitive user data. Web applications rely on two fundamental security mechanisms: **authentication** and **authorization**.

Authentication is the process of verifying the identity of a user using credentials such as a username and password.

Authorization determines what actions or resources an authenticated user is permitted to access within the system.

Difference Between Authentication and Authorization

Authentication	Authorization
Verifies the identity of a user	Determines access permissions
Confirms <i>who</i> the user is	Controls <i>what</i> the user can access
Implemented during login	Enforced after successful login
Uses credentials like username and password	Uses roles and access policies
Failure prevents login	Failure restricts access to resources

The absence of proper authorization, even when authentication is present, can result in serious security vulnerabilities. This project presents a case study of such a scenario in a university student portal and explains how role-based authorization can prevent unauthorized access.

This distinction forms the foundation for analysing access control vulnerabilities in real-world web applications.

2 PROJECT SCOPE AND COVERAGE

- ✓ Study of authentication mechanisms
- ✓ Study of authorization mechanisms
- ✓ Comparison between authentication and authorization
- ✓ Identification of broken access control vulnerabilities
- ✓ Analysis of security risks and impact
- ✓ Role-based access control (RBAC) solution
- ✓ Secure password handling using hashing techniques
- ✓ Case study analysis of a university student portal

3 OBJECTIVES OF THE PROJECT

The objectives of this minor project are:

- To understand the concepts of authentication and authorization in web applications.
- To analyse a scenario where authorization is missing despite authentication being present.
- To demonstrate the security risks caused by improper access control.
- To propose a secure solution using role-based authorization.
- To highlight the importance of access control in preventing unauthorized actions.

4 PROBLEM SCENARIO

4.1 System Overview

The case study considers a university student portal used for academic management. The portal supports multiple types of users, including:

- Students
- Faculty
- Administrator

All users access the system through a common login page using a username and password. The system correctly verifies the credentials during login, ensuring that authentication is implemented.

4.2 Description of the Vulnerability

Although authentication is present, the application does not implement proper authorization checks. After successful login, the system fails to validate user roles before granting access to specific pages.

As a result:

- Students can access faculty-only pages
- Students can manipulate URLs to reach restricted pages
- Sensitive operations, such as grade management, are exposed to unauthorized users

Example:

`/student/dashboard`

`/faculty/dashboard`

A student user can manually enter the faculty dashboard URL and gain access without restriction.

4.3 Cause of the Vulnerability

The root cause of this vulnerability is the absence of role-based access control (RBAC). The application does not verify whether the authenticated user has the required permissions before allowing access to protected resources.

This demonstrates a common security flaw where authentication is implemented without proper authorization, leading to broken access control.

5 SECURITY RISKS AND IMPACT

The absence of proper authorization in a web application can lead to serious security risks. Even though users are authenticated, unrestricted access to sensitive resources exposes the system to misuse and abuse.

Key Risks Identified:

- **Unauthorized Access:**
Students can access faculty-only pages and functions without permission.
- **Data Manipulation:**
Unauthorized users may modify academic records such as grades, attendance, or internal data.
- **Privilege Escalation:**
A user with limited privileges can gain higher-level access by exploiting missing authorization checks.
- **Data Leakage:**
Sensitive information related to faculty or other students can be exposed.
- **Loss of Trust:**
Such vulnerabilities can damage the credibility of the institution and reduce user trust in the system.

Impact on the Organization:

If this vulnerability exists in a real-world environment, it could result in academic integrity issues, legal consequences, and reputational damage. This highlights the importance of enforcing authorization controls in addition to authentication.

PROPOSED SECURE SOLUTION

To prevent unauthorized access and secure the web application, both **authentication** and **authorization** must be implemented correctly. The proposed solution focuses on strengthening authentication and enforcing role-based authorization.

6.1 Secure Authentication

Authentication should ensure that user identities are verified securely before granting access to the system. The following practices are recommended:

- Store user passwords using secure hashing algorithms such as **bcrypt** or **SHA-256**
- Avoid storing passwords in plain text
- Validate user credentials securely during login
- Use secure session management after successful authentication

These measures ensure that user identities are protected even if the database is compromised.

What is bcrypt?

bcrypt is a **password hashing algorithm** used to securely store user passwords in applications.

Instead of saving passwords in plain text, bcrypt converts them into an **irreversible encrypted hash**. Even if the database is compromised, the original password cannot be easily recovered.

What is SHA-256?

SHA-256 (Secure Hash Algorithm – 256 bit) is a **cryptographic hashing algorithm** used to convert data (like passwords) into a fixed-length 256-bit hash value. It is a **one-way function**, meaning the original input cannot be retrieved from the hash. For password storage, SHA-256 should be used with salting to enhance security.

6.2 Role-Based Authorization (RBAC)

Authorization should be enforced using a **role-based access control** approach. Each user in the system is assigned a specific role:

- **Student**
- **Faculty**
- **Administrator**

Access rules are defined based on user roles:

- Students can access only student-related pages
- Faculty can access faculty-related pages
- Administrators can access administrative functions

Before allowing access to any page or resource, the system must verify:

- Whether the user is authenticated
- Whether the user has the required role to access that resource

If the role does not match, access is denied or the user is redirected to an appropriate page.

6.3 Authorization Enforcement Flow

The secure access flow works as follows:

1. User logs in to the system
2. Credentials are authenticated securely
3. User role is stored in the session
4. Each request checks the user role before granting access
5. Unauthorized access attempts are blocked

This ensures that authenticated users cannot access resources beyond their permissions.

7 CONCLUSION

This minor project successfully demonstrates the importance of implementing both authentication and authorization in web applications. Through the analysis of a university student portal, it was observed that authentication alone is insufficient to secure sensitive resources. The absence of proper authorization allowed unauthorized users to access restricted pages, leading to potential data misuse and security breaches. By implementing role-based access control, the system can effectively restrict access based on user roles and prevent privilege escalation. This case study highlights how small security oversights can result in serious vulnerabilities and emphasizes the need for secure access control mechanisms in real-world applications.

8 LEARNING OUTCOMES

Through this project, the following learning outcomes were achieved:

- Clear understanding of authentication and authorization concepts
- Identification of broken access control vulnerabilities
- Awareness of security risks caused by improper authorization
- Knowledge of role-based access control implementation
- Practical understanding of securing web applications